

AI Audit Report — Mẫu 5 mục cho mỗi Artifact

Phụ lục bắt buộc đính kèm cho mọi bài tập có dùng AI (HW#01–HW#06, Seminar).

1. Thông tin Sinh viên

Mục	Giá trị
Họ tên sinh viên (in hoa):	PHẠM ĐỨC TOÀN
MSSV:	23127540
Lớp / Khoá:	23KTPM2
Mã bài tập (ví dụ HW#00, HW#02):	HW#06
Ngày làm bài:	2026-08-19
Công cụ AI đã dùng:	Gemini 3.6 Flash / Gemini 3.7 Flash — Antigravity AI IDE
Có dùng AI không:	☒ Có ☐ Không

2. Hướng dẫn (đọc trước khi điền)

- Thêm 1 hàng cho mỗi artifact AI sinh (test case, script, checklist, OpenAPI spec, Postman collection...).
- Dán nguyên văn prompt — KHÔNG paraphrase.
- Dán nguyên văn output AI (hoặc kèm screenshot có chú thích trong báo cáo).
- Gắn nhãn: VALID / INVALID / INCOMPLETE.
- Lý do phải dẫn chiếu slide, mục ISTQB, hoặc RFC kỹ thuật.
- Hiển thị bản sửa với phần thay đổi được tô sáng.

3. Bảng Audit — 1 hàng / artifact

(1) Prompt + Công cụ	(2) Output AI	(3) Verdict	(4) Lý do (ISTQB / Heuristic)	(5) Bản SV sửa
Artifact #1 — Sinh Test Cases Domain Partition & Boundary Values (FR-01, FR-06, FR-07, FR-12) Tool: Gemini 3.6 Flash — Antigravity IDE Thời gian: 2026-08-19 09:15 Prompt: "Dựa vào api_specification.md của SUT EShop, hãy sinh bộ test case API phân vùng tương đương (Equivalence Partitioning) và giá trị biên (Boundary Value Analysis) cho 4 tính năng: FR-01 Đăng ký, FR-06 Chi tiết sản phẩm, FR-07 Giỏ hàng, FR-12 Phân quyền Admin."	AI sinh danh sách 35 test case/API tập trung vào các trường cơ bản (email thiếu @, mật khẩu ngắn, ID sản phẩm âm, số lượng = 0). AI giả định rằng SUT sẽ luôn trả về <code>400 Bad Request</code> khi dữ liệu đầu vào không hợp lệ hoặc chuỗi rỗng.	INCOMPLETE	Theo nguyên tắc ISTQB (Boundary Value Analysis & Equivalence Partitioning), AI đã bỏ sót các vùng biên đặc thù: RFC 5322 email subaddressing (<code>(user+tag@domain.com)</code>), tràn số an toàn JavaScript (<code>Number.MAX_SAFE_INTEGER + 1</code>), chuỗi khoảng trắng UTF-8 và null-byte. Ngoài ra, AI giả định SUT hoạt động hoàn hảo mà không xét việc SUT thiếu validation tầng controller dẫn đến HTTP 500 SQLite crash thay vì 400.	Bổ sung đầy đủ các ca kiểm thử biên: kiểm tra unicode/whitespace trong name/password, trường hợp ID dạng float/hex/string trên FR-06, số lượng âm/quá lớn trên FR-07. Điều chỉnh Expected Status phản ánh đúng lỗi thực tế của SUT để audit.
Artifact #2 — Sinh Test Cases Security & State Transitions (SEC-01..SEC-07 & State Machine) Tool: Gemini 3.6 Flash — Antigravity IDE Thời gian: 2026-08-19 10:30 Prompt: "Hãy sinh các test case chuyên sâu về Security (SEC-01 đến SEC-07: SQL Injection, Broken Access Control, Privilege Escalation, Token Tampering) và State Transition cho FR-01, FR-06, FR-07, FR-12."	AI tạo các test case SQL Injection cho ô tìm kiếm sản phẩm và các test case kiểm tra token hết hạn. Với các endpoint Admin (FR-12), AI gán expected status là <code>403 Forbidden</code> khi người dùng thông thường gửi kèm token <code>user</code>.	INVALID	AI mắc lỗi nghiêm trọng khi giả định SUT đã cài đặt phân quyền Role-based Access Control (RBAC). Phân tích mã nguồn <code>server.js</code> cho thấy middleware <code>authenticateToken</code> chỉ kiểm tra tính hợp lệ của chữ ký JWT mà hoàn toàn không kiểm tra <code>req.user.role === 'admin'</code>. Do đó, SUT thực tế trả về <code>200 OK</code> cho phép user thường truy cập trái phép API Admin (Lỗi hỏng Broken Access Control SEC-01). AI cũng bỏ sót lỗi hỏng Mass Assignment ở <code>PUT /api/users/me</code> cho phép tự thăng cấp <code>role: 'admin'</code>.	Sửa lại toàn bộ bộ test case Security: Gắn nhãn phát hiện lỗi (Defect / Vulnerability), thiết lập test case kiểm tra quyền hạn thực tế của Token, bổ sung ca kiểm thử Privilege Escalation (thăng quyền qua <code>PUT /api/users/me</code>), khai thác chuyển trạng thái phi logic (hủy đơn hàng <code>canceled</code> chuyển sang <code>delivered</code>).

(1) Prompt + Công cụ	(2) Output AI	(3) Verdict	(4) Lý do (ISTQB / Heuristic)	(5) Bản SV sửa
Artifact #3 — Sinh Postman Collection & Automated Scripts (Pre-request & pm.test) Tool: Gemini 3.6 Flash — Antigravity IDE Thời gian: 2026-08-19 11:20 Prompt: "Hãy viết Postman Collection JSON (v2.1.0) tự động inject header X-Student-Id: 23127540 vào tất cả request bằng Pre-request Script, quản lý dynamic token qua Environment Variables và viết assertion pm.test cho status code, response schema."	AI sinh file JSON Postman collection chứa các request cơ bản. Tuy nhiên, AI gán header <code>X-Student-Id</code> thủ công tại từng request một thay vì gán tập trung ở Collection Pre-request Script. Test script của AI chỉ kiểm tra <code>pm.response.to.have.status(200)</code> mà không kiểm tra cấu trúc JSON Schema hay thông điệp lỗi.	IN C O M P L E T	Việc gán header thủ công vi phạm nguyên tắc bảo trì kịch bản kiểm thử (DRY - Don't Repeat Yourself) và dễ gây thiếu sót khi chạy runner. Thiếu Schema Validation khiến test script bỏ sót các trường hợp API trả về sai kiểu dữ liệu (ví dụ giá tiền dạng string thay vì number).	Tái cấu trúc Collection: Chuyển toàn bộ logic inject header <code>X-Student-Id: 23127540</code> vào Collection Pre-request Script cấp cao nhất: <pre>pm.request.headers.add({ key: 'X-Student-Id', value: pm.environment.get('studentId') '23127540' })</pre> . Bổ sung assertion kiểm tra kiểu mảng (Array) cho Giỏ hàng và schema JSON cho chi tiết sản phẩm.
Artifact #4 — Phân tích Lỗ hổng & Lập Bug Report cho Backend SUT Tool: Gemini 3.6 Flash — Antigravity IDE Thời gian: 2026-08-19 12:00 Prompt: "Dựa trên kết quả chạy test và đối soát code server.js của SUT EShop, hãy lập danh sách các Bug và Lỗ hổng bảo mật nghiêm trọng kèm vị trí dòng code và cách tái hiện."	AI liệt kê 2 lỗi: Lỗi không kiểm tra email trùng khi đăng ký và lỗi SQL Injection ở ô tìm kiếm sản phẩm. AI kết luận hệ thống giỏ hàng và phân quyền admin hoạt động bình thường.	IN VA LI D	AI bỏ sót 3 lỗ hổng bảo mật tối nghiêm trọng (Critical Vulnerabilities): (1) Broken Access Control tại toàn bộ endpoint <code>/api/admin/*</code> do thiếu check role admin; (2) Mass Assignment Privilege Escalation tại <code>PUT /api/users/me</code> dòng 124 cho phép user tự đổi role thành admin; (3) Price Tampering tại <code>POST /api/cart</code> dòng 161 cho phép client tự gửi giá tiền tùy ý vào giỏ hàng.	Bác bỏ kết luận của AI, bổ sung chi tiết 5 Bug Report hoàn chỉnh trong file <code>Bug_Report.md</code> : BUG-01 (Broken Admin Access Control), BUG-02 (Privilege Escalation via <code>PUT /api/users/me</code>), BUG-03 (SQLi trong Product Search), BUG-04 (Thiếu Validation trên <code>POST /api/register</code>), BUG-05 (Chuyển trạng thái đơn hàng bất hợp lệ từ <code>canceled</code> sang <code>delivered</code>).

(1) Prompt + Công cụ	(2) Output AI	(3) Verdict	(4) Lý do (ISTQB / Heuristic)	(5) Bản SV sửa
Artifact #5 — Thiết kế AI-driven API Test Generator (Agent Skill Architecture & Code) Tool: Gemini 3.6 Flash — Antigravity IDE Thời gian: 2026-08-19 12:40 Prompt: "Hãy thiết kế kiến trúc Agent Skill Test Generator tự động đọc tài liệu api_specification.md để sinh ra các kịch bản test API Postman/CSV, vẽ sơ đồ Mermaid và viết mã nguồn Python hoàn chỉnh."	AI sinh sơ đồ Mermaid mô tả pipeline xử lý 4 giai đoạn (Spec Parser -> Generator Engine -> Validator -> Exporter) và script Python <code>test_generator.py</code> sử dụng Regex bóc tách endpoint và sinh test case có gắn nhãn Audit.	VALID	Thiết kế tuân thủ mô hình AI-Agent chuẩn (Bloom G9.5 Create), phân tách rõ ràng các module phân vùng tương đương, kiểm tra bảo mật (SEC-01..07) và xuất định dạng JSON/CSV sẵn sàng tích hợp CI/CD.	Giữ nguyên kiến trúc và bổ sung xử lý bóc tách tham số path/query string động, hoàn thiện file <code>test_generator/architecture.md</code> và <code>test_generator/test_generator.py</code>.

4. Tổng kết Độ chính xác AI

Tổng hợp verdict từ Mục 3 và điền vào bảng dưới:

Chỉ số	Số lượng	Tỉ lệ
Tổng artifact AI sinh đã audit	5	100%
VALID (đúng, dùng nguyên)	1	20%
INVALID (sai; loại bỏ/sửa toàn diện)	2	40%
INCOMPLETE (chấp nhận sau khi bổ sung/sửa)	2	40%

5. Kết luận — Khi nào nên / không nên dùng AI?

AI (Gemini / Claude / GPT) là công cụ cực kỳ đắc lực trong việc **tăng tốc khởi tạo (Boilerplate Generation)**: dựng nhanh khung test cases theo chuẩn phân vùng tương đương, viết nhanh các file cấu hình Postman JSON phức tạp và thiết kế kiến trúc Agent Skill.

Tuy nhiên, **tuyệt đối không được tin tưởng hoàn toàn vào AI trong việc đánh giá an ninh bảo mật và logic trạng thái nghiệp vụ chuyên sâu**. AI luôn có xu hướng "ngây thơ" giả định rằng server backend tuân thủ đặc tả và có đầy đủ cơ chế bảo vệ. Thực tế kiểm thử cho thấy chỉ có con người thông qua kỹ thuật Static Code Analysis (đọc trực tiếp `server.js`) và Dynamic Security Testing mới có thể phát hiện ra các lỗi hỏng Broken Access Control, Privilege Escalation hay Logic State Flaw mà AI hoàn toàn bỏ qua.

6. Mandatory Disclosure (dán nguyên văn)

"Kế hoạch thực hiện, danh mục test case cho 4 tính năng (FR-01 Account Registration, FR-06 Product Detail, FR-07 Shopping Cart, FR-12 Access Control), Postman Collection JSON, script Agent Skill test generator và báo cáo này được sinh phiên bản đầu bởi Gemini 3.6 Flash / Gemini 3.7 Flash thông qua Antigravity AI IDE; tôi đã trực tiếp rà soát và chỉnh sửa: (1) bổ sung các ca kiểm thử biên RFC email,

SQLi và tấn công tràn số an toàn JS, (2) bác bỏ giả định sai lầm của AI về cơ chế phân quyền admin để vạch trần lỗ hổng Broken Access Control (SEC-01) trên các endpoint /api/admin, (3) phát hiện lỗ hổng Privilege Escalation trên PUT /api/users/me và Price Tampering trên POST /api/cart mà AI bỏ sót, (4) tái cấu trúc Postman Collection inject header X-Student-Id: 23127540 tập trung qua Collection Pre-request Script, (5) hoàn thiện hệ thống test generator script và tích hợp pipeline CI/CD GitHub Actions; phần chạy kiểm thử Newman, đối soát mã nguồn backend server.js và kiểm chứng lỗi do tôi tự thực hiện. AI Audit Report chi tiết đính kèm ở file này. Tôi cam đoan không dùng AI để sinh bất kỳ artifact nào thuộc danh mục bị cấm."

Chữ ký

Họ tên sinh viên (in hoa):	PHẠM ĐỨC TOÀN
MSSV:	23127540
Lớp / Khoá:	23KTPM2
Môn học:	CSC13003 – Kiểm chứng Phần mềm
Giảng viên:	TS. Lâm Quang Vũ
Ngày:	2026-08-19
Chữ ký:	Toàn